

ABC COMPANY

CYBERSECURITY INCIDENT REPORT

Distributed Denial of Service (DDoS) Attack

Report ID	INC-2025-0514-DDoS	Classification
Date of Incident	May 14, 2025	CONFIDENTIAL
Report Date	May 19, 2025	Severity
Prepared By	J. Carter, Lead Forensic Analyst — CSIRT	CRITICAL
Reviewed By	M. Reyes, CISO — ABC Company	Status
Version	1.0 — Final	RESOLVED

1. Executive Summary

On May 14, 2025, ABC Company experienced a large-scale Distributed Denial of Service (DDoS) attack targeting its public-facing web infrastructure. The attack began at approximately 09:17 AM (UTC+7) and caused complete unavailability of the company's customer portal and e-commerce platform for a period of 4 hours and 38 minutes. The incident was detected by the Security Information and Event Management (SIEM) system and escalated immediately to the Computer Security Incident Response Team (CSIRT).

The attack was characterized by a volumetric UDP flood combined with a Layer 7 HTTP GET flood, peaking at 94 Gbps of inbound traffic — approximately 47 times the company's normal peak bandwidth. Total estimated financial impact is USD \$312,000, comprising lost revenue, emergency mitigation costs, and staff overtime.

All affected services were fully restored by 13:55 PM on May 14, 2025. This report documents the full scope of the incident, response actions taken, forensic findings, and recommendations to prevent recurrence.

Metric	Value
Incident Start	May 14, 2025 — 09:17 AM (UTC+7)

Metric	Value
Incident End	May 14, 2025 — 01:55 PM (UTC+7)
Duration	4 hours, 38 minutes
Peak Attack Volume	94 Gbps / 18.3 Mpps
Systems Affected	3 web servers, 1 load balancer, DNS resolver
Data Exfiltration Confirmed	None
Estimated Financial Impact	USD \$312,000
Incident Severity	CRITICAL
Current Status	RESOLVED

2. Incident Background

2.1 How the Incident Was Detected

At 09:17 AM, the SIEM platform (Splunk Enterprise Security v8.2) generated a high-priority alert — Rule ID: NET-4421 — flagging an abnormal inbound traffic spike on the primary internet gateway (FW-EDGE-01). Network monitoring dashboards showed traffic rising from a baseline of 1.9 Gbps to 94 Gbps within 4 minutes. NOC staff escalated to the CSIRT on-call lead at 09:22 AM.

2.2 Systems and Assets Affected

Asset	Type	IP Address	Impact
WEB-PROD-01	Web Server (Apache)	10.10.5.11	Fully unavailable
WEB-PROD-02	Web Server (Apache)	10.10.5.12	Fully unavailable
WEB-PROD-03	Web Server (Apache)	10.10.5.13	Fully unavailable
LB-PROD-01	HAProxy Load Balancer	10.10.5.1	CPU saturated (99%)
DNS-RESOLVER-01	Internal DNS Resolver	10.10.1.5	Degraded — partial failures
CDN Edge Node (BKK-01)	Cloudflare PoP	203.185.xx.xx	Traffic rerouted

2.3 Nature and Severity of the Incident

Incident Type: Distributed Denial of Service (DDoS) — Volumetric + Application Layer

Severity Level: **CRITICAL**

Attack Vector: External — Internet-facing infrastructure

Attack Type: UDP Amplification Flood (Layer 3/4) + HTTP GET Flood (Layer 7)

Botnet Nodes Identified: Approximately 12,400 unique source IPs across 38 countries

Peak Traffic: 94 Gbps inbound / 18.3 million packets per second (Mpps)

2.4 Indicators of Compromise (IOCs)

IOC Type	Value	Notes
Source IP Range (Sample)	185.220.101.0/24	Known Tor exit / botnet range
Source IP Range (Sample)	91.108.4.0/24	Associated with DDoS-for-hire service
Source IP Range (Sample)	45.141.215.0/24	Prior DDoS activity on threat intel feeds
Amplification Source	Misconfigured DNS resolvers	DNS amplification factor ~50x
Amplification Source	Open NTP servers	NTP monlist abuse
HTTP User-Agent (malicious)	Mozilla/5.0 (DDoS_Tool_v3.1)	Automated attack tool signature
HTTP Request Pattern	GET /search?q=[random 512-char string]	Cache-busting flood pattern
Attack Coordination C2	Suspected Telegram channel	Identified via OSINT; not confirmed

3. Incident Response Timeline

All times are in UTC+7 (Bangkok, Thailand — ABC Company HQ timezone).

Time	Event	Responsible Party
09:17 AM	SIEM alert triggered — inbound traffic spike detected on FW-EDGE-01 (Rule NET-4421). Alert severity: Critical.	SIEM / Splunk Auto-Alert
09:22 AM	NOC analyst escalates to CSIRT on-call lead (J. Carter). Initial phone bridge opened.	NOC Analyst T. Suphan
09:26 AM	CSIRT incident declared. Incident commander assigned. Incident channel #inc-2025-0514 opened in Slack.	J. Carter — CSIRT Lead
09:31 AM	Traffic confirmed as DDoS. Attack volume confirmed at 52 Gbps and rising. ISP (TrueMove Business) notified for upstream blackhole routing.	J. Carter / Network Team
09:38 AM	Cloudflare DDoS protection activated — traffic rerouted through scrubbing center. Mitigation partially effective.	P. Nakorn — Network Engineer
09:45 AM	Peak attack volume reaches 94 Gbps. Cloudflare scrubbing overwhelmed. Rate limiting rules deployed at edge firewall.	P. Nakorn / CSIRT
09:52 AM	CISO (M. Reyes) and VP of Operations notified. Leadership bridge call initiated.	J. Carter

Time	Event	Responsible Party
10:10 AM	ISP upstream null routing activated for primary public IP block. Backup IP range brought online for critical services.	ISP NOC / P. Nakorn
10:35 AM	Customer-facing portal partially restored via secondary IP range. Attack traffic shifting toward new IPs.	P. Nakorn / CSIRT
10:50 AM	Layer 7 HTTP flood component identified. WAF rules deployed to block malicious HTTP GET patterns and rate-limit per-IP.	S. Wongsu — Security Analyst
11:15 AM	Attack traffic begins decreasing. Total inbound traffic drops to 22 Gbps.	CSIRT / NOC
11:40 AM	All web servers returning valid HTTP 200 responses. Load balancer CPU normalizing (18%).	NOC Monitoring
12:30 PM	Attack subsides. Residual traffic at 3 Gbps (within normal range). All scrubbing rules maintained as precaution.	CSIRT
01:55 PM	All services declared fully operational. Customer portal, e-commerce platform, and DNS fully restored.	J. Carter — Incident Commander
02:30 PM	Post-incident monitoring watch period begins (48-hour elevated alert threshold).	NOC / CSIRT
May 15, 2025 09:00 AM	Initial forensic analysis complete. IOC list distributed to threat intel team.	S. Wongsu — Forensic Analyst
May 19, 2025	Final incident report completed and submitted to CISO.	J. Carter — CSIRT Lead

4. Response Actions Taken

4.1 Containment Actions

- **ISP-Level Upstream Null Routing:** Coordinated with TrueMove Business to activate BGP blackhole routing for the primary /24 public IP block. This removed the flooded IPs from routing tables, offloading traffic before it reached company infrastructure.
 - Rationale: Required to stop network congestion saturating the upstream link
 - Trade-off: Temporarily made primary IPs unreachable; mitigated by activating backup IP range
- **Cloudflare DDoS Scrubbing Activation:** Emergency DDoS protection mode enabled on Cloudflare; all inbound traffic tunneled through scrubbing PoPs in Singapore and Tokyo.
 - Rationale: Volumetric DDoS requires scrubbing at scale beyond on-premises capability
- **Edge Firewall Rate Limiting:** Deployed ACL rules on FW-EDGE-01 blocking source IP ranges matching known botnet ASNs (12 ASNs blocked). Per-IP connection rate limited to 50 req/sec.
- **DNS Rate Limiting:** Configured DNS-RESOLVER-01 to drop recursive queries from external IPs exceeding 100 queries/sec.

4.2 Mitigation Actions

- **WAF Layer 7 Rules Deployed:** Custom rules added to block HTTP GET requests with query strings exceeding 256 characters and User-Agent strings matching known DDoS tool signatures.
- **Geo-blocking Implemented (Temporary):** Countries with highest attack traffic concentration (RU, BY, UA, CN, VN) geo-blocked at the CDN level for the duration of the attack.
 - Note: Geo-blocking was temporary and lifted after attack subsided to avoid impacting legitimate users
- **Emergency Bandwidth Upgrade:** ISP emergency bandwidth burst activated — uplink expanded from 2 Gbps to 10 Gbps for the duration of the incident.

4.3 Remediation and Recovery Actions

- **Service Restoration:** Customer portal services progressively restored via backup IP ranges with WAF protection enabled.
- **Firewall Rule Review:** All temporary firewall rules reviewed; 8 rules permanently retained, 4 temporary geo-blocks removed after 24 hours.
- **Patch Deployment:** DNS resolver software patched to disable recursive DNS for external clients (post-incident, May 15).
- **Communication:** Customer-facing status page updated at 10:05 AM acknowledging degraded service; updated again at 01:55 PM confirming full restoration.

5. Forensic Analysis Findings

5.1 Root Cause Analysis

The DDoS attack was a coordinated, multi-vector assault combining:

- **Layer 3/4 UDP Amplification:** Attackers exploited misconfigured open DNS resolvers and NTP servers on the public internet to amplify traffic directed at ABC Company's infrastructure. DNS amplification provided a traffic multiplication factor of approximately 50x.
- **Layer 7 HTTP Flood:** A botnet of approximately 12,400 compromised hosts sent high-rate HTTP GET requests with randomized query strings, designed to bypass caching and force backend processing on all three web servers.

The root causes enabling the severity of this attack were identified as:

- **Absence of Always-On DDoS Protection:** Cloudflare DDoS scrubbing was available but configured in 'on-demand' mode, requiring manual activation. This introduced a 21-minute gap between detection and effective mitigation.
- **No Upstream Traffic Scrubbing Agreement:** ABC Company had no pre-negotiated DDoS scrubbing SLA with its ISP, causing delays in activating upstream null routing (coordinating manual approval required 39 minutes).
- **Insufficient Baseline Bandwidth:** The 2 Gbps uplink was undersized relative to the potential attack scale, meaning even moderate DDoS traffic caused saturation.
- **Unpatched DNS Resolver Configuration:** DNS-RESOLVER-01 was improperly configured to accept recursive queries from external IP addresses, contributing to amplification risk.

5.2 Extent of Compromise

Category	Finding
Data Exfiltration	None confirmed. Attack was a DoS event; no evidence of data access or lateral movement.
Systems Compromised	No internal systems were compromised. Attack was limited to network saturation of perimeter.
Customer Data Impact	No customer data exposed. Customer portal was unavailable but backend databases unaffected.
Financial Transactions	Approximately USD \$245,000 in e-commerce revenue lost during 4h38m downtime window.
Third-Party Impact	API partners experienced downstream disruptions during the outage window.

5.3 Vulnerabilities Identified

Vulnerability	Severity	Description
V-001: No Always-On DDoS Protection	CRITICAL	Cloudflare in on-demand mode — manual activation required delay
V-002: Undersized Internet Uplink	HIGH	2 Gbps uplink insufficient; saturated at 94 Gbps attack volume
V-003: Open Recursive DNS Resolver	HIGH	DNS-RESOLVER-01 accepted external recursive queries
V-004: No ISP DDoS SLA	HIGH	No pre-negotiated upstream scrubbing or blackhole routing agreement
V-005: No Automated Geo-Blocking Rules	MEDIUM	Geo-blocking had to be manually configured during incident
V-006: Outdated DDoS Response Playbook	MEDIUM	Playbook did not include Layer 7 DDoS procedures; team improvised
V-007: Insufficient NOC DDoS Training	MEDIUM	NOC staff required CSIRT escalation rather than executing initial containment independently

6. Lessons Learned

6.1 What Went Well

- **Rapid Detection:** The SIEM alert triggered within seconds of the attack onset. The escalation from alert to CSIRT activation took only 9 minutes — within the 15-minute SLA target.
- **Effective Communication:** The incident command structure functioned well. The Slack incident channel and leadership bridge kept all stakeholders informed in real time.

- **ISP Coordination:** Despite the absence of a formal DDoS SLA, TrueMove Business responded to the emergency blackhole routing request within 39 minutes — a satisfactory response given no pre-existing agreement.
- **Customer Communication:** The status page was updated proactively, which reduced inbound support ticket volume by an estimated 40% compared to previous unplanned outages.
- **No Data Breach:** Effective perimeter controls prevented the DDoS attack from being leveraged as a smokescreen for data exfiltration — a common combined attack vector.

6.2 What Did Not Go Well

- **Manual DDoS Protection Activation:** The 21-minute gap before Cloudflare scrubbing was effective was the single largest contributor to extended downtime. Always-on protection would have dramatically reduced impact.
- **ISP Coordination Delay:** Without a pre-negotiated DDoS response SLA, obtaining upstream null routing approval required multiple approval escalations, taking 39 minutes.
- **Layer 7 Detection Gap:** The HTTP GET flood component of the attack was not identified until 33 minutes after the initial volumetric alert, as WAF alerting rules were not tuned for cache-busting patterns.
- **Playbook Gaps:** The existing DDoS response playbook was outdated and did not include procedures for Layer 7 application-layer floods. CSIRT analysts had to improvise containment steps.
- **DNS Misconfiguration Undetected:** The open recursive DNS resolver configuration (V-003) had existed in production for an estimated 14 months without detection, indicating a gap in periodic configuration audits.

7. Recommendations

ID	Recommendation	Priority	Owner	Target Date
R-001	Enable Always-On Cloudflare DDoS Protection on all public-facing properties. Upgrade to Cloudflare Enterprise Advanced DDoS plan.	CRITICAL	Network Team	Jun 1, 2025
R-002	Negotiate formal DDoS Response SLA with TrueMove Business ISP including pre-authorized null routing procedures and 15-minute response commitment.	CRITICAL	IT Director	Jun 15, 2025
R-003	Upgrade primary internet uplink from 2 Gbps to 10 Gbps with burst capability to 40 Gbps.	HIGH	Network Team / Procurement	Jul 1, 2025
R-004	Remediate open recursive DNS resolver (V-003) — restrict external recursive queries. Conduct full DNS infrastructure audit.	HIGH	Network Team	May 25, 2025
R-005	Update DDoS Incident Response Playbook to include Layer 7 attack procedures, automated geo-blocking runbooks, and ISP coordination scripts.	HIGH	CSIRT Lead	Jun 1, 2025

ID	Recommendation	Priority	Owner	Target Date
R-006	Deploy automated geo-blocking via Cloudflare Firewall Rules for high-risk country/ASN combinations, reviewable on a 90-day basis.	HIGH	Security Team	Jun 15, 2025
R-007	Implement WAF rules tuned for cache-busting HTTP flood patterns and anomalous User-Agent strings. Enable Layer 7 DDoS alerting in SIEM.	HIGH	Security Team / SOC	Jun 1, 2025
R-008	Conduct quarterly DDoS tabletop exercises and annual live DDoS simulation to validate playbook and staff readiness.	MEDIUM	CSIRT Lead	Aug 1, 2025
R-009	Implement automated configuration drift detection (using tools such as AWS Config or Ansible) to flag unauthorized or misconfigured network services monthly.	MEDIUM	Infrastructure Team	Jul 15, 2025
R-010	Brief executive leadership on DDoS risk landscape and obtain budget approval for R-001 through R-004 at the June board meeting.	MEDIUM	CISO	Jun 5, 2025

8. Appendices

Appendix A — Traffic Volume Graph Data (Summary)

Time (UTC+7)	Inbound Traffic (Gbps)	Legitimate Baseline (Gbps)	Packets/sec (Mpps)
09:10 AM	1.9	1.9	0.4
09:17 AM	8.2	1.9	1.6
09:22 AM	34.1	1.9	6.7
09:38 AM	72.4	1.9	14.1
09:45 AM	94.0 (PEAK)	1.9	18.3
10:10 AM	61.3	1.9	12.0
11:15 AM	22.7	1.9	4.4
12:30 PM	3.1	1.9	0.6
01:55 PM	2.0	1.9	0.4

Appendix B — Key IOC Reference List

The following IOCs have been submitted to the company threat intelligence platform (MISP) and shared with ISP and Cloudflare for blocklisting. Full IOC dump available in secure evidence archive: `/evidence/INC-2025-0514/ioc_full_export.json` (access restricted to CSIRT and CISO).

IOC	Type	Confidence	Action Taken
185.220.101.0/24	IP Range	High	Blocked at firewall + CDN
91.108.4.0/24	IP Range	High	Blocked at firewall + CDN
45.141.215.0/24	IP Range	High	Blocked at firewall + CDN
Mozilla/5.0 (DDoS_Tool_v3.1)	HTTP User-Agent	High	WAF rule deployed
GET /search?q=[512+chars]	HTTP Pattern	High	WAF rate limit applied
Open NTP servers (28 IPs)	Amplification Source	High	ISP null-routed
Open DNS resolvers (143 IPs)	Amplification Source	High	ISP null-routed

Appendix C — Personnel Involved

Name	Role	Responsibility During Incident
J. Carter	Lead Forensic Analyst / Incident Commander	Overall incident command, forensic analysis, report authorship
M. Reyes	CISO	Executive oversight, leadership communications, resource approval
P. Nakorn	Senior Network Engineer	Cloudflare activation, ISP coordination, firewall rules
S. Wongsu	Security Analyst	WAF rules, Layer 7 analysis, IOC identification
T. Suphan	NOC Analyst	Initial detection, escalation, service monitoring
K. Prasit	IT Operations Manager	Backup IP provisioning, service restoration coordination

Appendix D — Evidence and Artifacts

All evidence is stored in the secure forensic evidence repository (access: CSIRT only):

- `/evidence/INC-2025-0514/splunk_alerts_export_20250514.csv` — SIEM alert log export
- `/evidence/INC-2025-0514/fw_edge01_traffic_capture_0917-1400.pcap` — Full packet capture (145 GB)
- `/evidence/INC-2025-0514/cloudflare_traffic_analytics_20250514.json` — Cloudflare dashboard export
- `/evidence/INC-2025-0514/ioc_full_export.json` — Complete IOC list (12,400+ IPs)
- `/evidence/INC-2025-0514/dns_resolver_config_audit.txt` — DNS misconfiguration evidence

- /evidence/INC-2025-0514/waf_logs_layer7_flood_20250514.log — WAF Layer 7 alert logs
- /evidence/INC-2025-0514/isp_correspondence.pdf — Email thread with TrueMove Business NOC

Report Authorization

Prepared by:	J. Carter — Lead Forensic Analyst, CSIRT	Date:	May 19, 2025
Reviewed by:	M. Reyes — Chief Information Security Officer	Date:	May 19, 2025
Signature:	_____	Signature:	_____

This document contains confidential and proprietary information belonging to ABC Company. Unauthorized disclosure is prohibited.